EXPERIMENT 12

Implementing security features and governance / administration practices in Zoho Creator.

Student details	Project details
HARIHARAN N Register No. 241401024	Insurance Claim Request & Processing Management
Department: CSBS	Platform: Zoho Creator (India region)
Institution: Rajalakshmi Engineering College	Evidence / verification date: 19 October 2026

Aim

To examine and demonstrate role permissions, record ownership, field restrictions and administrative controls for the insurance-claim application.

Execution status

Existing RBAC and field protections were inspected and documented. Administrative governance settings were reviewed. Organization-wide MFA/password enforcement and a fresh separate-account penetration test were not performed.

Application context

The project records insurance requests, validates submitted details, assigns claims for processing and presents claim status and amount summaries. Existing forms, reports, Deluge workflows and permission profiles provide the base for this experiment.

Screenshots in this report are actual captures from the project account. Explanations, tables and code listings are documentation, not simulated platform screenshots.

Security model and procedure

1. Opened the insurance application settings and reviewed permission profiles and the role hierarchy.

2. Inspected the Policyholder profile for own-record visibility and restricted report actions.

3. Checked field visibility and read-only processing fields.

4. Reviewed the Governance / Security Policies area and distinguished available controls from configured controls.

5. Observed the notification guard during the synthetic record update: no email was sent for a blank/demo recipient.

Identity / control	Observed configuration or scope
Administrator	Full application control through administrative permissions.
Claims Officer	Claims_Officer_Processing profile for staff claim processing.
Policyholder	Can add claims and view permitted own records; no edit/delete, dashboard or API access in the inspected profile.
Bulk and privileged actions	Policyholder import, export, View All, Modify All, report creation and comments disabled.
Sensitive processing fields	Assigned Officer and Investigation Notes hidden; Claim ID, Status and Approval fields read-only.
Personal data	Existing classifications present for name, policy number, email, phone and address.

Security principle

A role hierarchy alone does not define effective access. The assigned permission profile, report access, field restrictions and record ownership must be evaluated together. Public submission must not be treated as an authenticated own-record status portal.

Evidence: permissions

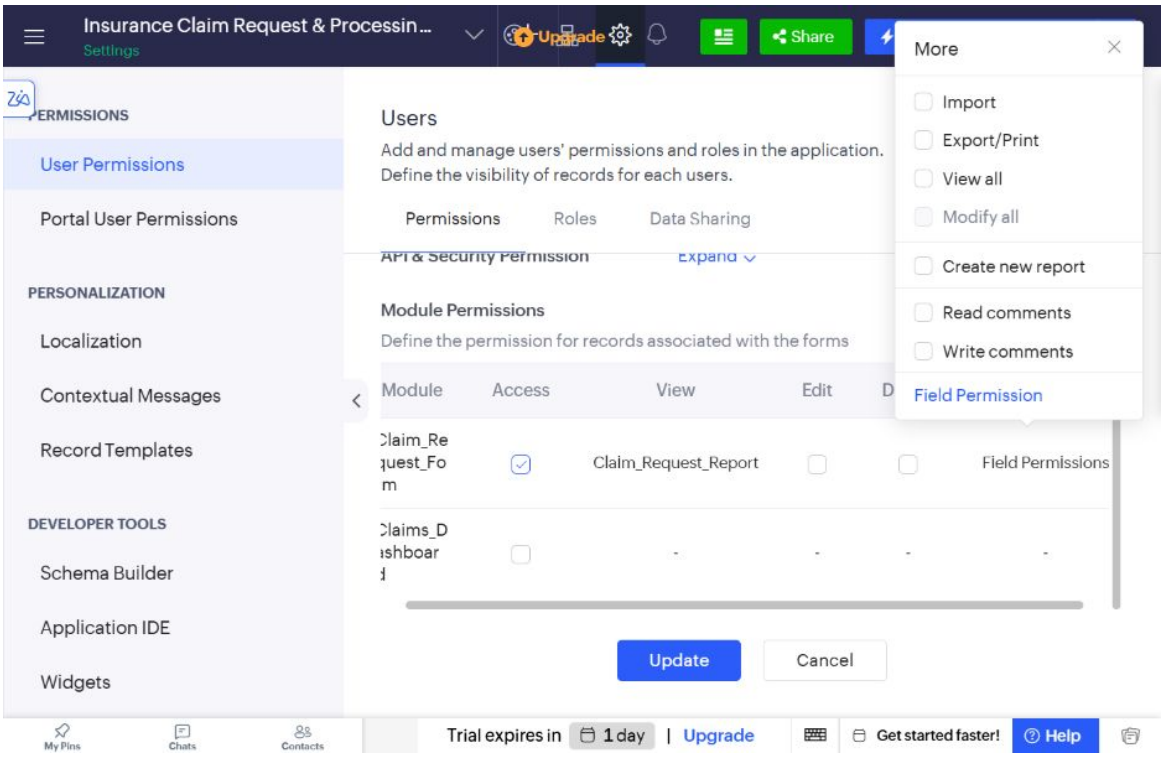


Figure 12.1 - Policyholder advanced actions disabled in the real permission profile.

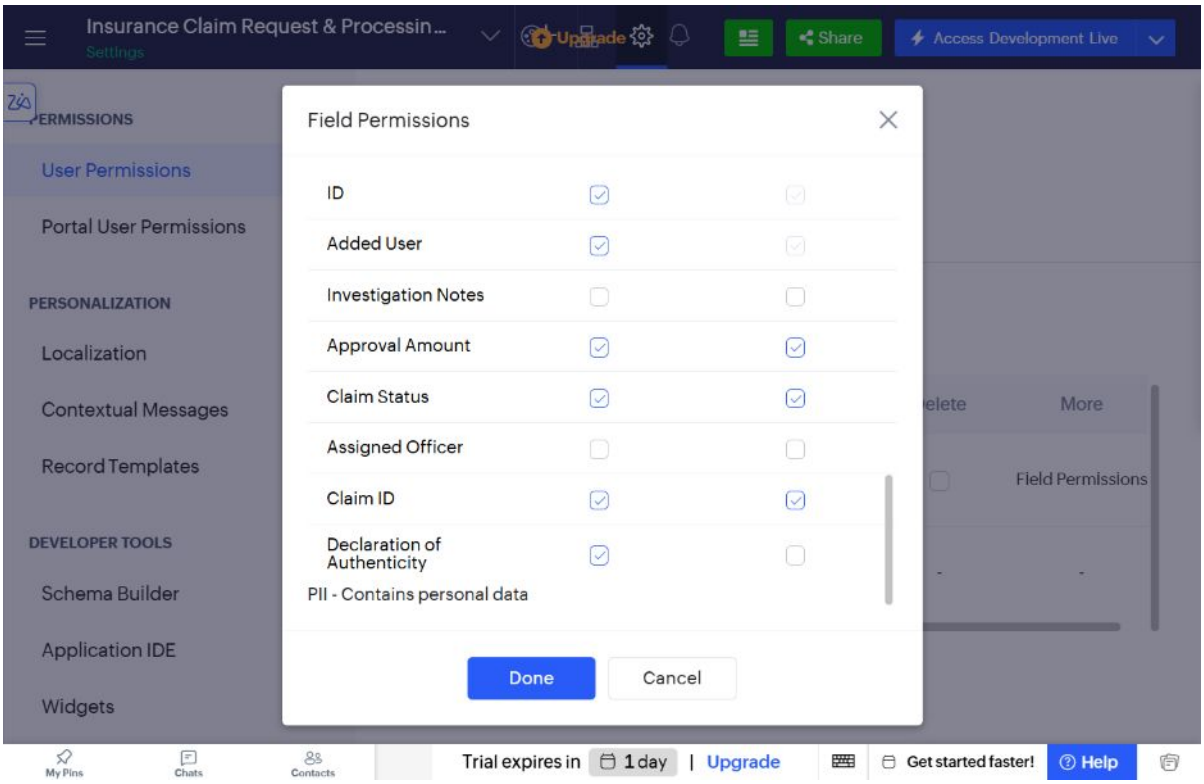


Figure 12.2 - Field visibility and read-only settings protect processing information.

Evidence: governance and findings

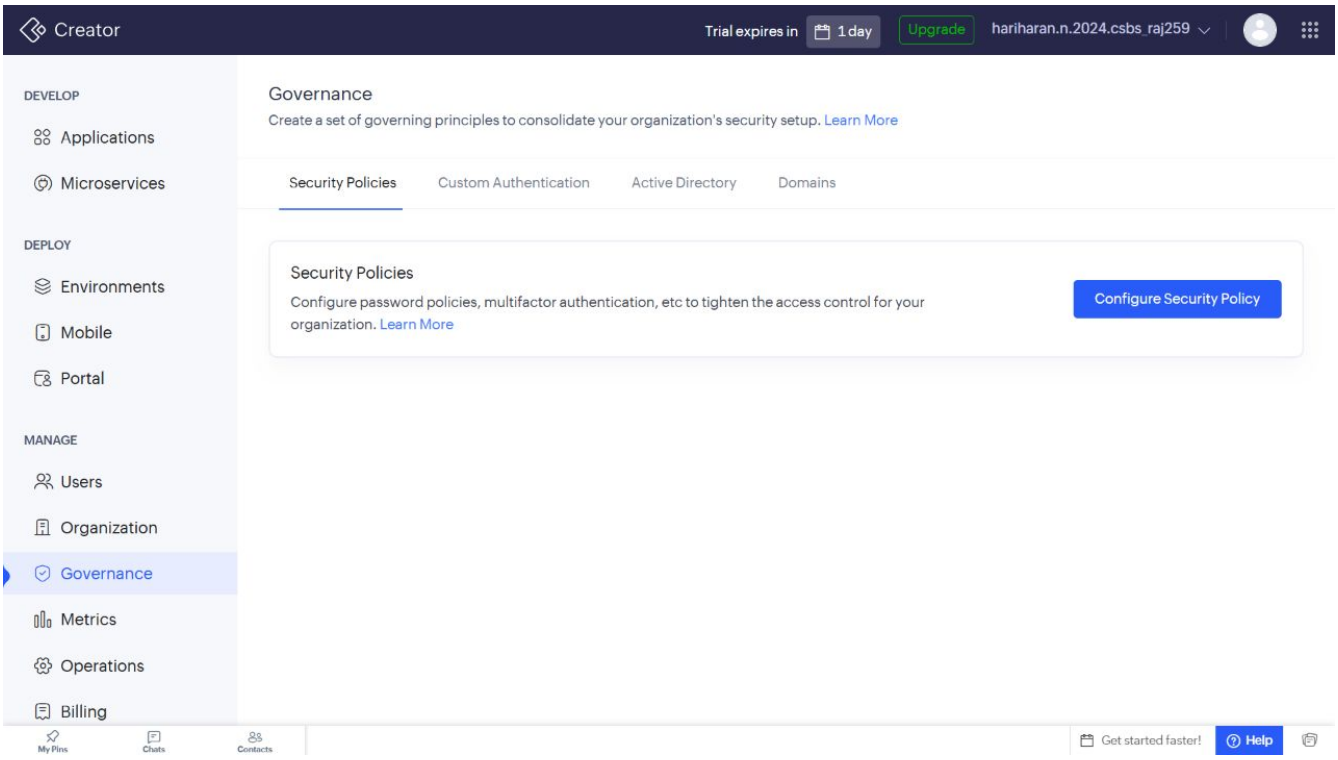


Figure 12.3 - Actual Governance security-policy screen; configuration availability is not proof that a policy is enabled.

Verification	Conclusion
Least privilege configuration	Own-record and restricted-action settings observed in the profile.
Demo email guard	Workflow output: Skipped: no live recipient or demo address.
Governance enforcement	Security-policy configuration was not completed; MFA/password enforcement is not claimed.
Remaining assurance	Repeat access tests using separate signed-in staff and policyholder identities, including attempted direct report/API access.

Result

Existing application security controls were documented with real evidence. The report separates verified configuration from tests not performed. Recommended administration includes periodic access review, controlled release approvals, restricted connection scopes and a documented recovery procedure.